

Azure Corporate Policy RAG

Phase 1 Security Guide for React, Azure Functions, Azure AI Search, Blob Storage, and an LLM

Recommended approach: Keep Phase 1 simple, but do not run it without security. Use a backend boundary, managed identities, least-privilege RBAC, private Blob storage, and sanitized test documents. API Management and private endpoints can wait until a later phase.

1. Corrected Phase 1 Architecture

The proposed components are appropriate, but the ingestion flow and query flow should be treated separately.

Ingestion flow	Query flow
Azure Blob Storage	React client
v	v
Azure AI Search indexer	Azure Function
v	v
Azure AI Search index	Azure AI Search
	v
	Azure OpenAI / Foundry LLM
	v
	Azure Function
	v
	React client

2. Minimum Security Controls by Connection

React client to Azure Function

- **Preferred:** Enable Microsoft Entra ID authentication on the Function App and require authenticated requests.
- **Temporary developer-only alternative:** Use a Function key for short-lived testing.

-  • Do not expose Azure AI Search or Azure OpenAI credentials in the React application.
- Keep local environment files out of source control. A browser-side secret should be treated as exposed.

Azure Function to Azure AI Search

- Enable a **system-assigned managed identity** on the Azure Function.
- Assign the Function identity the **Search Index Data Reader** role for query-only runtime access.
- Use **DefaultAzureCredential** or **ManagedIdentityCredential** in the Function code.
- While building the index, give your developer identity only the additional data permissions required. Do not give the runtime Function broad administrative rights.
- If an API key must be used temporarily, use a query key for search requests rather than an admin key.



Azure AI Search to Azure Blob Storage

- Enable a managed identity on the Azure AI Search service.
- Assign the Search identity **Storage Blob Data Reader** on the storage account or, preferably, the specific policy container.
- Keep the Blob container private and disable anonymous Blob access.
- Prefer managed identity over storage account keys or connection strings.

Azure Function to the LLM

- For Azure OpenAI, allow the Function managed identity to perform inference using the appropriate least-privilege role, commonly **Cognitive Services OpenAI User**.
- The Function should retrieve relevant chunks from Search, build the grounded prompt, call the LLM, and return the answer to React.
- Do not place the LLM key or endpoint credential in React.



3. Phase 1 Role Assignment Summary

Identity	Target resource	Minimum role or control
Developer account	Azure AI Search	Search Index Data Contributor while building and testing indexes; reduce access afterward
Azure Function managed identity	Azure AI Search	Search Index Data Reader
Azure AI Search managed identity	Blob Storage/container	Storage Blob Data Reader
Azure Function managed identity	Azure OpenAI	Cognitive Services OpenAI User or the equivalent least-privilege inference role
Test user	Azure Function endpoint	Microsoft Entra authenticated access; temporary Function key only for limited developer testing



4. Document and Data Rules for Phase 1

Document-level authorization can be deferred only when every test user is allowed to see every document in the test index. Use:

- Public, fabricated, or sanitized corporate-policy documents.
- No employee records, customer records, credentials, secrets, or legal-privileged content.
- No confidential HR, executive, financial, or security-operations documents.
- A separate development storage container and search index rather than production resources.

5. Controls You Can Postpone

The following controls are valuable for production but are not required to prove ingestion, retrieval, grounding, and generation:

- Azure API Management.
- Private endpoints and full virtual-network isolation.
- Web Application Firewall.
- Department-level or user-level document filtering.
- Advanced Entra groups and application roles.
- Customer-managed encryption keys.
- SIEM integration and advanced auditing.
- Disabling all public network access.

6. What Not to Do

Avoid this:

React browser -> Azure AI Search directly -> admin API key

An admin key exposed to browser code can be copied and used to modify or delete indexes and data.



7. Recommended Phase 1 Blueprint

```
React
+- Entra token, or temporary Function key
v
Azure Function
+- System-assigned managed identity
+- Search Index Data Reader
+- Cognitive Services OpenAI User
v
Azure AI Search
+- RBAC enabled
+- Managed identity
v
Private Blob container
+- Search identity has Storage Blob Data Reader
```

Bottom line: For Phase 1, the minimum acceptable foundation is no credentials in React, private test documents, authenticated access to the Function, managed identities between Azure services, and least-privilege RBAC. Add API Management, private networking, and document-level authorization after the basic RAG workflow is proven.

Reference topics: Microsoft Entra authentication for Azure Functions; Azure AI Search RBAC; managed identity for Blob indexers; Azure OpenAI role-based access control.